AssetTrust v0.63

Engineering security review | PostgreSQL RLS policy integrity | 11 November 2026

Security change	Production status
Fail-closed policy catalog verification	NO-GO / deployment blocked

1 Findings and remediation

Finding A - RLS flags alone cannot detect a new permissive policy. The previous startup check verified protected-table row-level-security flags and a restricted role. PostgreSQL combines permissive policies using OR logic; an unexpected policy can broaden access while RLS stays enabled.

Implemented: Startup now queries `pg_policies` for an approved inventory of **16 policies on 13 sensitive tables**. Missing, additional, duplicated, reassigned or modified policy definitions cause startup refusal in production and guarded CI. Notification rules must preserve both organization and recipient scope.

Finding B - incompatible clean-runner CI order. The v0.61-v0.63 TypeScript-dependent tests had been scheduled before `npm ci`. They now run after dependency installation; lockfile and dependency-free checks remain before installation.

2 Verified engineering evidence

Test / control	Observed result
New v0.63 tests	31 of 31 PASS
Historical + current version suites	61 of 61 PASS (v0.03-v0.63)
Pinned SQL migrations	27 of 27 unchanged from v0.62
Architecture, syntax, CI and source checks	PASS
High-confidence source secret patterns	0 matches in 2,939 inspected files
Read-only release prerequisites	3 of 11 present; NOT release approval

These are offline unit and source checks. Tests of the real PostgreSQL policy catalog and multi-organization behavior were **not** executed on a live database here.

Release decision and follow-up

Evidence boundaries, blocked commands and mandatory next tests

3 Tests not completed in this environment

Authentic dependency lockfile: Not available; the archive intentionally does not contain a fabricated package-lock.json.

Clean dependency installation: `npm ci --offline` blocked by the missing lockfile.

Full API + web build: `npm run build` fails on missing installed Node and NestJS dependencies; no successful compiled build is claimed.

Real PostgreSQL policy review: Guarded live checker correctly refuses to run without approved disposable database credentials; no local PostgreSQL service.

End-to-end security: ClamAV clean/infected checks, authenticated browser, real multi-instance HTTP, backup restore and independent security tests outstanding.

4 Residual security risks

• The catalog checker proves the approved policy names and expressions at one point in time, not tenant isolation against live malicious operations or guarantees about a privileged database administrator.

• Source-only secret scanning is limited. The original Git history and operational secret custody require independent inspection and rotation of any exposed keys.

• Other sensitive tables outside the 13-table reviewed inventory still require permissions, referential-integrity and tenant-isolation assessments.

5 Mandatory Kali / staging release gates

On a trusted connected machine: generate and review an authentic lockfile, run a clean npm install, audit dependencies, build API and web, and verify browser artifacts. On a **disposable local database**, apply reviewed migrations and run the new v0.63 catalog contract plus the v0.57-v0.62 restricted-role, audit, tenant CRUD and recipient-isolation contracts. Follow with malware scanning, end-to-end authenticated workflows, HTTPS/proxy tests, restore drills and independent security sign-off.

RELEASE DECISION: NO-GO. The updated source is suitable for development and controlled staging validation only.

Supporting materials: CHANGELOG_V63.md, TEST_EVIDENCE_V63.md, V63_HANDOVER.md and V63_KALI_VALIDATION.md.